# RMF Assessment: The State Institute of Science and Technology

# Monitor Task #1

## 1. Information Security Continuous Monitoring (ISCM) Strategy for SIST Web Infrastructure (SWI)

The Information Security Continuous Monitoring (ISCM) strategy for the simulated State Institute of Science and Technology (SIST) Web Infrastructure System (SWI) is designed to maintain awareness of the security posture of its High-impact AWS-hosted environment. The initial assessment includes the HR, GMAT, and FCIN applications. In accordance with NIST SP 800-137, the proposed strategy focuses on monitoring vulnerabilities, configuration changes, authentication activity, and security control effectiveness.

The proposed monitoring approach includes AWS CloudTrail for supported AWS API activity, Amazon CloudWatch Logs for configured system and application logs, Amazon S3 for audit log storage, and AWS Config for configuration compliance monitoring. These services represent planned monitoring capabilities rather than verified implementations. The Security Operations Center (SOC) and Information System Security Officer (ISSO) would evaluate monitoring results and report significant findings to system leadership and the Authorizing Official (AO) to support ongoing risk-based authorization decisions.

### a) Five Key Security Metrics for the SWI System

| Security Metric | Proposed Tool or Evidence | Monitoring Frequency |
|---|---|---|
| S3 Public Access Status | AWS Config and S3 Block Public Access settings | Daily and after configuration changes |
| Critical Vulnerability Count per Asset | Authorized vulnerability scanning reports | Weekly |
| Unauthorized Configuration Change Frequency | AWS Config and AWS CloudTrail | Continuous alerts where configured |
| Failed Authentication Attempts | Amazon CloudWatch Logs and relevant authentication logs | Daily review and alerting |
| Audit Log Integrity and Retention Compliance | S3 configuration, retention settings, and log validation evidence | Weekly |

## b) Monitoring, Alerting, and Reporting Tools

1. AWS CloudTrail
2. Amazon CloudWatch Logs
3. AWS Config

## c) Roles and Responsibilities

1. **Claire Jensen — Chief Information Security Officer (CISO):** Provides organizational security oversight and reviews significant security risks.
2. **Jens Martensson — System Owner:** Oversees system operations and supports risk management decisions.
3. **April Hansson — Information System Security Officer (ISSO):** Coordinates continuous monitoring activities, reviews findings, and reports security risks.
4. **Erik Lund — Security Operations Center (SOC) Manager:** Oversees security monitoring, alert investigation, and operational reporting.

## d) Monitoring Frequency and Reporting Schedule

1. **Vulnerability Scans:** Weekly, with monthly summary reviews.
2. **Real-Time Monitoring:** Continuous (24/7), where monitoring capabilities are configured.
3. **Security Reports:** Daily reports for the SOC, weekly reports for the ISSO, and monthly reports for the CISO.

## 2. Most Important Risk Management Tier

Tier 3 — Information System Level is the primary focus of this monitoring strategy because the assessment evaluates security risks and controls within the SIST Web Infrastructure System. However, monitoring results also support Tier 2 mission and business process decisions and Tier 1 organizational risk management.

## 3. Most Responsible Role

The Information System Security Officer (ISSO) is responsible for coordinating system-level monitoring activities, reviewing findings, and reporting security risks. The Chief Information Security Officer (CISO) provides organization-wide security oversight, while the Authorizing Official (AO) is responsible for accepting authorization risk and making authorization decisions.

# Monitor Task #2

## 1. Reauthorization Following Infrastructure Migration

The proposed decommissioning of Azure and migration of infrastructure to AWS and the SIST Data Center would require a security impact analysis because these changes could affect system boundaries, inherited controls, data flows, and the overall risk posture. The System Security Plan (SSP) and related security documentation would need to be updated. The Authorizing Official would determine whether reauthorization is necessary based on the significance of the changes and the updated risk assessment.

## 2. New Risks and Potential Impacts

1. **Cloud and Data Center Misconfiguration Risk:** Incorrect security configurations in AWS or the SIST Data Center could expose sensitive information, weaken access controls, and create security vulnerabilities.
2. **Loss of Azure Inherited Controls:** Decommissioning Azure could remove security controls previously provided by Azure. If these controls are not replaced, the system could experience security gaps and increased risks.
3. **Expanded Attack Surface:** Migrating infrastructure to AWS and the SIST Data Center could introduce new systems, services, and network connections that attackers might exploit.
4. **Insider Threat:** Changes to user accounts and permissions during migration could increase the risk of unauthorized access or misuse of sensitive information.
5. **Data Migration Risk:** Transferring data from Azure to AWS or the SIST Data Center could result in data loss, corruption, or unauthorized exposure if appropriate security measures are not implemented.

## 3. Changes to the SSP and POA&M

**SSP Updates**

- Update system boundaries by removing decommissioned Azure components and incorporating newly migrated assets within the revised authorization boundary, as applicable.
- Revise architecture diagrams and data flows to reflect the proposed infrastructure changes.
- Update the inventory of hardware and software components.
- Update common control providers by removing Azure as an inherited control provider where applicable and reviewing the continued roles of AWS, Zscaler, SISTNet, and Equinix.

**POA&M Updates**

- Add confirmed control deficiencies identified through migration assessments.
- Track remediation actions related to AWS and Data Center security configurations.
- Establish remediation timelines for replacing or reimplementing inherited security controls previously provided by Azure.

# Monitor Task #3 — Assumptions and Recommendations

## Assumptions

- The SIST Web Infrastructure System retains its High-impact categorization unless a revised assessment determines otherwise.
- The initial AWS-focused environment may transition to a broader hybrid AWS and SIST Data Center environment following the proposed migration.
- Zscaler remains a proposed external authentication or remote access service provider, subject to confirmation of its responsibilities and inherited controls.

## Recommendation 1: Automated Configuration Compliance Monitoring

Implement AWS Config and appropriate configuration monitoring for on-premises systems to identify unauthorized or noncompliant changes. Alerts and periodic reviews would help the security team identify configuration weaknesses and initiate corrective actions.

## Recommendation 2: Strengthen Identity and Access Management

Review IAM policies, privileged accounts, and access permissions across AWS and the SIST Data Center. Following Azure decommissioning, reassess authentication dependencies and inherited controls to ensure that access management responsibilities remain clearly assigned.

## Recommendation 3: Centralized Logging and Security Monitoring

Establish a centralized approach for collecting and reviewing relevant AWS and Data Center security logs. Evaluate integration with a security information and event management (SIEM) platform to support event correlation, incident detection, and investigation. The GMAT application's monitoring functions may contribute to this strategy, but should not be described as a verified SIEM implementation.

# References

National Institute of Standards and Technology. (2011). *Information Security Continuous Monitoring (ISCM) for Federal Information Systems and Organizations (NIST SP 800-137).* https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-137.pdf

National Institute of Standards and Technology. (2020). *Security and Privacy Controls for Information Systems and Organizations (NIST SP 800-53 Rev. 5).* https://doi.org/10.6028/NIST.SP.800-53r5

National Institute of Standards and Technology. (2018). *Risk Management Framework for Information Systems and Organizations (NIST SP 800-37 Rev. 2).* https://doi.org/10.6028/NIST.SP.800-37r2

Amazon Web Services. (2024). *AWS CloudTrail User Guide.* https://docs.aws.amazon.com/cloudtrail/

Amazon Web Services. (2024). *Amazon CloudWatch User Guide.* https://docs.aws.amazon.com/cloudwatch/

Amazon Web Services. (2024). *Amazon S3 User Guide.* https://docs.aws.amazon.com/s3/